

Autenticación de APIs

Tokens, OAuth 2.0, JWT y controles de acceso en APIs.

Autenticación vs autorización

La autenticación demuestra identidad; la autorización determina qué puede acceder esa identidad.

OAuth 2.0 y tokens

Los access tokens son comunes. QA debe validar tokens ausentes, inválidos, expirados, scopes incorrectos y renovación cuando aplique.

JWT

JWT es un formato de token. Valide firma, expiración, claims y comportamiento de la API; decodificar el payload no demuestra validez.

Cuándo utilizarlo

Utilice este conocimiento cuando el riesgo, la arquitectura o la etapa de entrega requieran este tipo de validación. Confirme objetivo, ambiente, datos necesarios y evidencias esperadas antes de comenzar.

Cómo lo aplica QA

Parta del comportamiento o riesgo que debe validarse, prepare datos y ambiente, ejecute la técnica o herramienta de forma reproducible y registre evidencias que ayuden al equipo a comprender el resultado.

Buenas prácticas

Priorice escenarios de mayor impacto, mantenga datos y ambientes controlados, registre decisiones importantes y revise periódicamente el enfoque para evitar cobertura redundante o desactualizada.

Consejo de QA

Relacione siempre la práctica con el riesgo del producto y la evidencia necesaria para decisiones de calidad.

Recursos oficiales

Site oficial: <https://datatracker.ietf.org/doc/html/rfc6749>